

TRYHACKME - RELATÓRIO TÉCNICO

Análise de Superfície Web e Auditoria de Autenticação

Enumeração de conteúdo com Gobuster e teste controlado com Hydra

Autor: Amilcar Junior

Plataforma: TryHackMe

Data: 28 de agosto de 2026

Classificação: laboratório autorizado

Sumário

1. Resumo executivo	3
2. Escopo e autorização	3
3. Objetivos	3
4. Fundamentos técnicos	4
5. Ambiente e ferramentas	5
6. Metodologia	5
7. Evidências: ambiente e enumeração	6
8. Evidências: auditoria de autenticação	7
9. Achados técnicos	8
10. Cadeia de risco e impacto	8
11. Recomendações defensivas	9
12. Perspectiva SOC e detecção	10
13. Mapeamento de segurança	11
14. Competências demonstradas	11
15. Limitações	11
16. Conclusão	11

Nota de publicação

Todas as evidências deste relatório foram revisadas para remover credenciais, flags e respostas do laboratório. O material registra somente o necessário para demonstrar metodologia, análise e aprendizado.

1. Resumo executivo

Este relatório documenta uma avaliação controlada da superfície de uma aplicação web fictícia no TryHackMe. O exercício combinou descoberta de conteúdo com análise do mecanismo de autenticação, demonstrando como fragilidades aparentemente pequenas podem formar uma cadeia de risco quando não existem controles defensivos suficientes.

A atividade envolveu preparação de enumeração automatizada com Gobuster e auditoria de autenticação com Hydra, utilizando uma lista reduzida fornecida pelo laboratório. O comportamento observado indicou que tentativas repetidas puderam ser processadas até a identificação de uma credencial válida. O valor do exercício está menos na ferramenta e mais na interpretação: autenticação fraca, ausência ou insuficiência de limitação de tentativas e baixa visibilidade operacional podem transformar um endpoint comum em vetor de acesso indevido.

Resultado principal

Foi possível encadear descoberta de endpoint, análise de formulário e tentativas controladas de autenticação. A credencial encontrada e qualquer resposta sensível foram removidas desta versão pública.

2. Escopo e autorização

O alvo pertence a um ambiente educacional isolado do TryHackMe e foi disponibilizado especificamente para experimentação. Nenhuma técnica foi aplicada contra sistemas reais, terceiros ou ativos fora do escopo. O domínio apresentado nas capturas é fictício e restrito ao laboratório.

- Escopo: aplicação web simulada e seus endpoints de laboratório.
- Autorização: atividade prevista pelo próprio ambiente educacional.
- Restrições: nenhuma exploração fora das tarefas propostas; nenhum dado real coletado.
- Publicação: credenciais, flags e respostas foram sanitizadas.

3. Objetivos

- Identificar conteúdo e endpoints que não estavam destacados na navegação principal.
- Compreender o funcionamento de uma autenticação baseada em formulário HTTP POST.
- Avaliar, de forma controlada, o efeito de senhas fracas e tentativas repetidas.
- Relacionar os eventos observados a controles de prevenção, monitoramento e resposta de um SOC.

4. Fundamentos técnicos

Uma aplicação web expõe rotas, arquivos, APIs e formulários que compõem sua superfície de ataque. Parte desse conteúdo pode não aparecer em menus ou links visíveis, mas ainda responder diretamente quando o caminho correto é solicitado. Ferramentas de descoberta de conteúdo automatizam a comparação de nomes de uma wordlist com as respostas do servidor.

O Gobuster opera nesse contexto: envia requisições para possíveis caminhos e permite ao analista observar quais respostas diferem de um erro de página inexistente. A descoberta de uma rota, porém, não prova vulnerabilidade. Endpoints administrativos e páginas de login devem continuar protegidos por autenticação, autorização, monitoramento e controles contra abuso, independentemente de estarem listados publicamente.

Princípio essencial

Ocultar uma rota não é controle de segurança. A proteção deve permanecer eficaz mesmo quando o endereço do endpoint é conhecido.

Na autenticação por formulário, o cliente envia credenciais ao servidor, normalmente por uma requisição POST. Ferramentas de auditoria, como o Hydra, podem repetir esse fluxo com entradas de uma lista controlada. Em um teste autorizado, isso ajuda a validar se o sistema aplica políticas de senha, limitação de frequência, bloqueio progressivo, MFA e alertas operacionais.

Um ataque de dicionário utiliza uma lista predefinida de combinações prováveis. Ele se diferencia de uma busca exaustiva porque prioriza termos comuns, padrões previsíveis e senhas frequentemente reutilizadas. Se o sistema aceita muitas tentativas em sequência e possui uma credencial fraca, o custo do ataque diminui consideravelmente.

A perspectiva defensiva é observar a cadeia completa: várias falhas em curto intervalo, repetição contra a mesma conta, volume incomum de POST para o endpoint de login e eventual sucesso após uma sequência de erros. Esses sinais podem alimentar regras de correlação, alertas no SIEM e procedimentos de resposta.

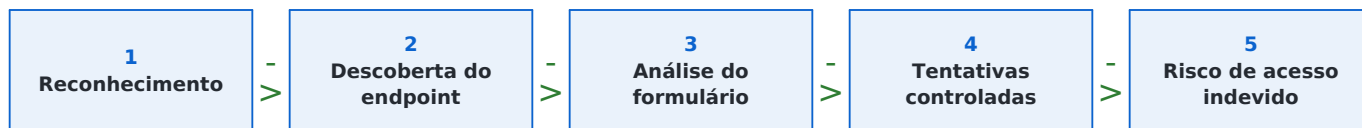
Conceito	Aplicação defensiva
Enumeração	Inventariar rotas e identificar conteúdo não referenciado.
Autenticação	Validar identidade com controles proporcionais ao risco.
Rate limiting	Reduzir a velocidade e o volume de tentativas automatizadas.
Telemetria	Registrar falhas, sucessos, origem, conta e contexto da sessão.
Correlação	Detectar sucesso de login precedido por várias falhas.

5. Ambiente e ferramentas

Componente	Uso no laboratório
TryHackMe	Ambiente isolado e autorizado para execução do cenário.
Navegador	Reconhecimento visual e verificação controlada de rotas.
Terminal Linux	Execução das ferramentas e registro do comportamento observado.
Gobuster	Preparação da descoberta automatizada de conteúdo web.
Hydra	Auditoria controlada do formulário de autenticação.
Wordlists	Conjuntos limitados de caminhos e senhas fornecidos pelo laboratório.

6. Metodologia

- Reconhecimento inicial da aplicação e identificação da navegação disponível.
- Verificação manual de caminhos previstos no exercício para compreender respostas válidas e erros 404.
- Preparação da enumeração automatizada com Gobuster e wordlist de diretórios.
- Identificação do endpoint de autenticação e análise dos campos enviados pelo formulário.
- Configuração de uma auditoria controlada com Hydra e uma lista reduzida de senhas do laboratório.
- Observação das tentativas, validação do resultado e registro das evidências.
- Sanitização da credencial válida antes da elaboração desta versão pública.



Os comandos abaixo foram generalizados para evitar transformar a documentação em instrução direcionada a um alvo específico. Seu uso é apropriado somente em ativos próprios ou formalmente autorizados.

```
gobuster dir --url http://<ALVO_AUTORIZADO>/ -w <WORDLIST>

hydra -l <USUARIO_TESTE> -P <WORDLIST> <ALVO_AUTORIZADO> \
http-post-form "/login:username=^USER^&password=^PASS^:F=<FALHA>" -V
```

7. Evidências: ambiente e enumeração

A primeira etapa consistiu em reconhecer a aplicação disponibilizada no navegador do laboratório e preparar o terminal para as verificações. A captura estabelece o alvo educacional e o ambiente controlado utilizado durante toda a atividade.

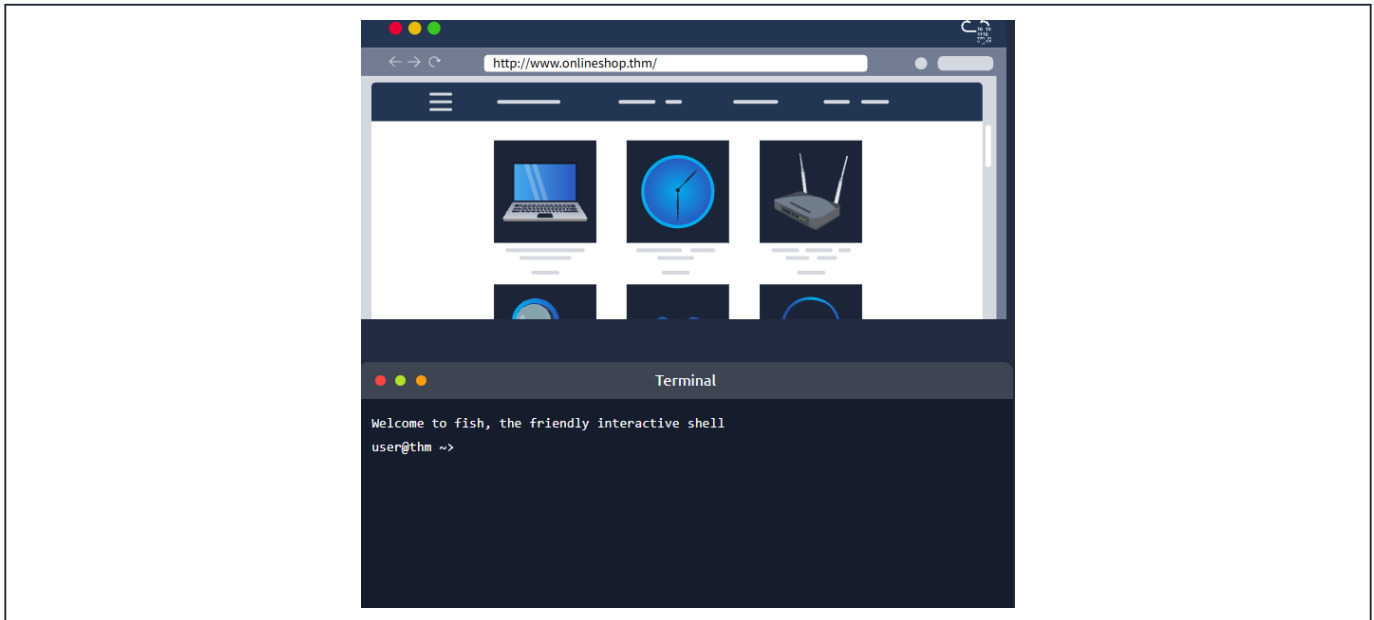


Figura 1: Aplicação web fictícia e terminal do ambiente autorizado do TryHackMe.

Em seguida, foi preparada a enumeração automatizada com uma wordlist de diretórios. A imagem registra a configuração do caminho e da lista utilizada, mas não apresenta o comando completo nem o resultado final. Por isso, esta evidência é tratada apenas como preparação da etapa, sem atribuir descobertas que não estejam visíveis.

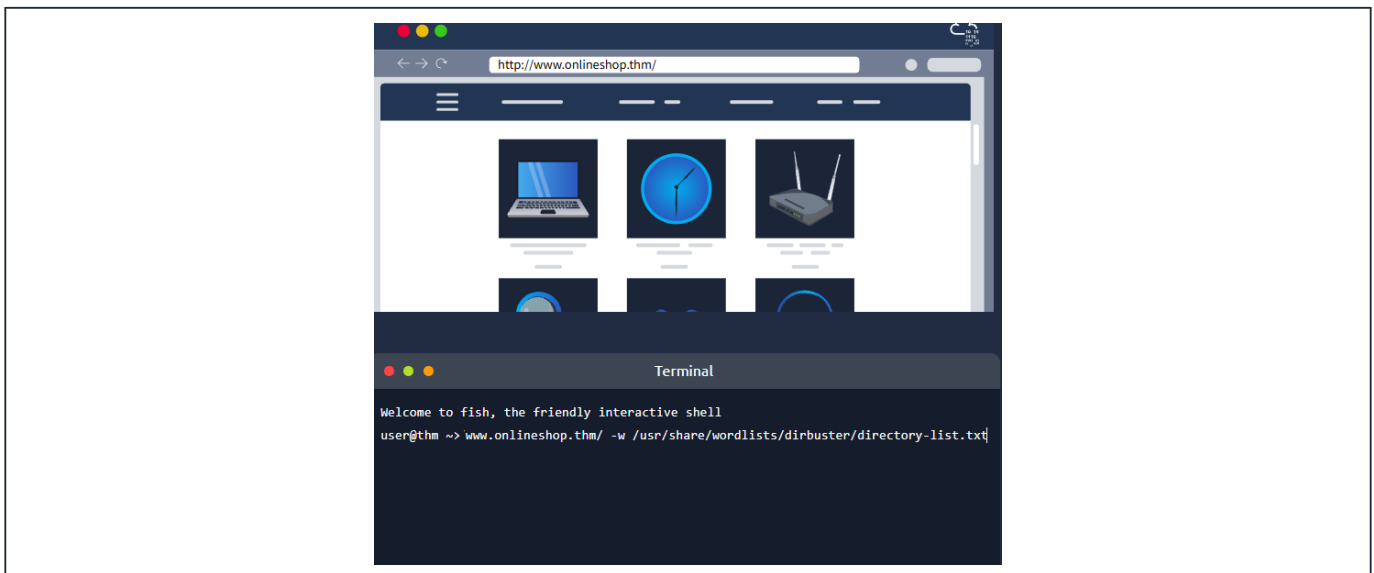
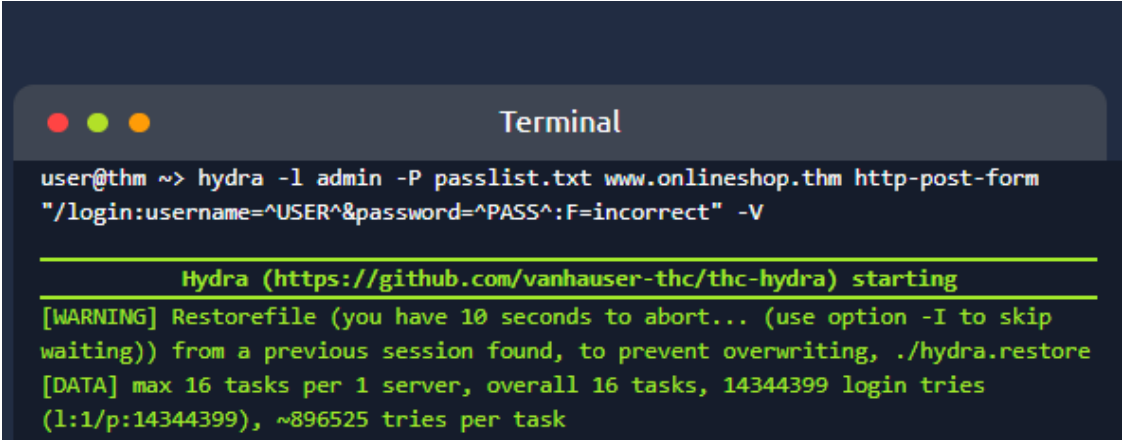


Figura 2: Preparação da wordlist para a enumeração automatizada de conteúdo.

8. Evidências: auditoria de autenticação

Após a identificação do fluxo de autenticação, o Hydra foi configurado para reproduzir requisições POST contra o formulário do laboratório. A evidência abaixo foi recortada antes da exibição das senhas candidatas, preservando apenas a inicialização, o alvo autorizado, a wordlist e o módulo de formulário.

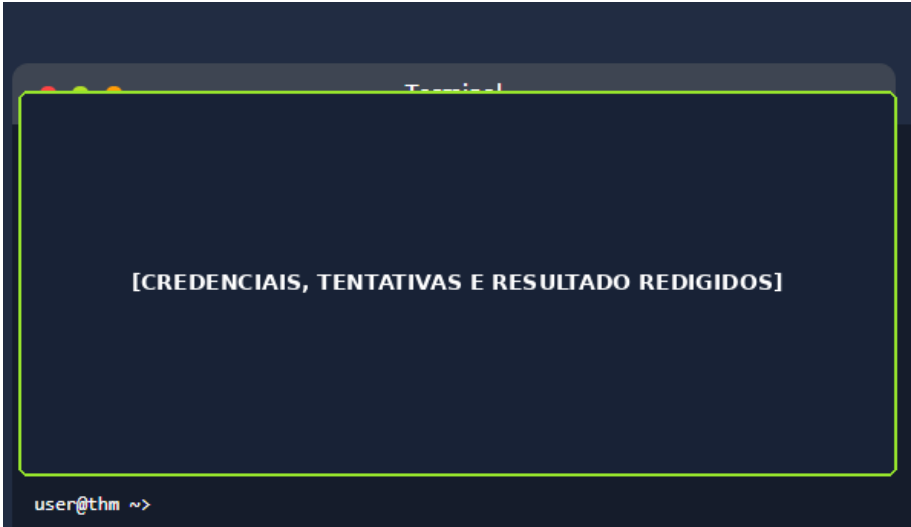


```
user@thm ~> hydra -l admin -P passlist.txt www.onlineshop.thm http-post-form
"/login:username=^USER^&password=^PASS^:F=incorrect" -V

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip
waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries
(1:1/p:14344399), ~896525 tries per task
```

Figura 3: Inicialização da auditoria controlada de autenticação com Hydra.

O processamento das tentativas indicou que uma combinação válida existia no conjunto de teste. Os valores tentados, a credencial e o resultado sensível foram integralmente substituídos por uma marca de redação. A evidência sanitizada registra a conclusão da etapa sem publicar senhas ou respostas do laboratório.



```
user@thm ~>

[CREDENCIAIS, TENTATIVAS E RESULTADO REDIGIDOS]
```

Figura 4: Resultado do teste com credencial e informação sensível removidas.

Tratamento da evidência

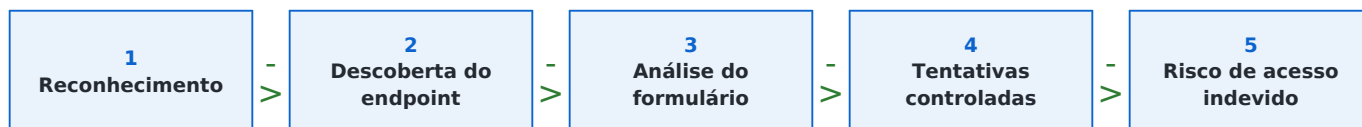
A versão original da captura não foi incorporada ao PDF. Somente a cópia sanitizada integra este relatório.

9. Achados técnicos

Achado	Evidência e interpretação	Risco
Endpoint de autenticação identificável	A rota pôde ser alcançada durante a descoberta de conteúdo. Isso amplia a superfície observável, mas não é vulnerabilidade isolada.	Informativo
Credencial fraca no cenário	Uma combinação presente em uma lista curta permitiu concluir a autenticação.	Alto
Tentativas repetidas aceitas	A ferramenta conseguiu processar uma sequência de entradas até identificar um resultado válido.	Alto
Telemetria defensiva necessária	Sem alertas para falhas repetidas e sucesso posterior, a atividade pode não receber resposta rápida.	Médio

10. Cadeia de risco e impacto

O cenário demonstra um encadeamento. A descoberta de uma página de login representa apenas o primeiro passo. O risco aumenta quando a conta utiliza uma senha previsível, o sistema permite muitas tentativas e a operação não gera alertas úteis para investigação.



- Acesso a funcionalidades destinadas somente a usuários autenticados.
- Visualização ou alteração indevida de dados do aplicativo.
- Uso abusivo de funções administrativas, caso a conta possua privilégios elevados.
- Expansão para outras falhas disponíveis na área autenticada.
- Comprometimento de contas reutilizadas em outros serviços.

Classificação do risco

O risco principal não é a página estar oculta ou visível. Ele está na combinação entre autenticação fraca, possibilidade de automação e ausência ou insuficiência de controles compensatórios.

11. Recomendações defensivas

As medidas abaixo devem atuar em camadas. Nenhum controle isolado elimina o risco, mas a combinação de prevenção, detecção e resposta aumenta significativamente o custo de tentativas automatizadas.

Prioridade	Controle	Aplicação recomendada
Crítica	MFA	Exigir segundo fator, principalmente para contas administrativas e acessos de risco.
Crítica	Rate limiting	Limitar tentativas por conta, origem, dispositivo e janela de tempo.
Alta	Bloqueio progressivo	Aumentar o intervalo entre tentativas sem criar bloqueio permanente explorável para negação de serviço.
Alta	Política de senhas	Bloquear senhas comuns, exigir comprimento adequado e verificar credenciais comprometidas.
Alta	Logging e alertas	Registrar falha, sucesso, origem, conta, user-agent, sessão e decisão do controle.
Média	Mensagens genéricas	Evitar indicar se usuário ou senha específica está incorreta.
Média	CAPTCHA adaptativo	Aplicar após comportamento suspeito, sem depender dele como único controle.
Média	Revisão de contas	Remover contas padrão, inativas ou com privilégios desnecessários.

Defesa em profundidade

A autenticação deve permanecer resistente mesmo quando o endpoint, o nome de usuário ou o funcionamento do formulário são conhecidos. Segurança por obscuridade não substitui controles verificáveis.

Para reduzir a exposição de conteúdo não referenciado, recomenda-se inventariar rotas em cada implantação, remover páginas antigas ou de teste, restringir endpoints administrativos, revisar arquivos de configuração e incluir testes de descoberta de conteúdo no ciclo de desenvolvimento seguro.

12. Perspectiva SOC e detecção

Em uma operação SOC, o objetivo seria reconhecer o padrão antes ou imediatamente após um acesso bem-sucedido. Uma tentativa isolada é comum; várias falhas concentradas contra a mesma conta ou endpoint formam um sinal mais relevante quando correlacionadas com origem, intervalo e resultado final.

Sinal	Exemplo de lógica	Ação inicial
Falhas repetidas	Múltiplos POST para /login com falha na mesma janela de tempo.	Validar origem, conta, frequência e reputação.
Conta sob ataque	Muitas origens tentando a mesma identidade.	Investigar password spraying e proteger a conta.
Origem automatizada	Uma origem tentando várias senhas ou contas em sequência.	Aplicar contenção e revisar outros eventos da origem.
Sucesso após falhas	Login válido imediatamente após sequência anormal de erros.	Tratar como possível comprometimento e escalar.
Mudança de contexto	Novo IP, dispositivo, geolocalização ou user-agent após as falhas.	Revalidar sessão, redefinir credencial e revisar atividade.

Fluxo sugerido de triagem

- Confirmar se o alerta corresponde a ambiente produtivo, teste autorizado ou falso positivo.
- Preservar evidências: horário, IP de origem, conta, endpoint, user-agent e resultados.
- Verificar se houve autenticação bem-sucedida e atividade posterior na conta.
- Conter quando necessário: invalidar sessão, bloquear origem, exigir redefinição e MFA.
- Escalonar conforme criticidade, privilégio da conta e impacto observado.
- Documentar decisão, ações, responsáveis e horário de cada etapa no chamado.

Regra de correlação sugerida

Gerar alerta de alta prioridade quando uma autenticação bem-sucedida for precedida por várias falhas para a mesma conta, origem ou endpoint em curto intervalo.

13. Mapeamento de segurança

Referência	Relação com o cenário
OWASP A07:2021	Falhas de identificação e autenticação, incluindo senhas fracas e proteção insuficiente contra automação.
CWE-307	Restrição inadequada de tentativas excessivas de autenticação.
CWE-521	Requisitos insuficientes para escolha e uso de senhas fortes.
MITRE ATT&CK T1110.001	Password Guessing: tentativa de identificar uma senha válida para uma conta conhecida.

14. Competências demonstradas

- Reconhecimento de aplicações e enumeração de conteúdo web.
- Interpretação de formulário HTTP POST e respostas de autenticação.
- Uso controlado de Gobuster, Hydra e wordlists em ambiente autorizado.
- Análise de encadeamento de fragilidades, risco, impacto e mitigação.
- Registro, seleção e sanitização de evidências técnicas.
- Pensamento defensivo aplicado a alertas, triagem e resposta de SOC.

15. Limitações

A captura de enumeração não apresenta o comando completo nem seus resultados; por isso, nenhuma rota específica foi atribuída a essa imagem. A wordlist de autenticação era pequena e definida pelo próprio exercício. Não foram avaliados controles além dos disponibilizados no cenário, nem realizados testes fora do escopo autorizado.

16. Conclusão

O laboratório demonstrou como automação pode acelerar tarefas repetitivas de descoberta e validação. Mais importante, evidenciou que o resultado técnico precisa ser interpretado dentro de uma cadeia: um endpoint conhecido não é uma falha por si só, mas senhas fracas, tentativas sem restrição adequada e baixa capacidade de detecção podem permitir acesso indevido.

A documentação reforça competências relevantes para Segurança Web, SOC, MSS e Blue Team: análise de comportamento, coleta de evidências, avaliação de impacto, recomendação de controles e construção de sinais de detecção. Todo o exercício foi conduzido em ambiente autorizado, e os dados sensíveis foram removidos da versão pública.